

Jean Victor Borges de Abreu

Análise da Transição para Algoritmos criptográficos Pós-Quânticos nos modelos NIST

Petrópolis -Rio de Janeiro

2026

Jean Victor Borges de Abreu

Análise da Transição para Algoritmos criptográficos Pós-Quânticos nos modelos NIST

Trabalho de Conclusão de Curso apresentado
à

FACULDADE DE EDUCAÇÃO TECNOLÓGICA DO ESTADO DO RIO DE JANEIRO
FAETERJ/PETRÓPOLIS

Orientador: Nome do Orientador

Petrópolis -Rio de Janeiro
2026

1 Resumo

2 Abstract

3 Lista de Abreviaturas

ABNT: Associação Brasileira de Normas Técnicas CSPRNG: Cryptographically Secure Pseudo Random Number Generator DRBG: Deterministic Random Bit Generator FAETERJ: Faculdade de Educação Tecnológica do Estado do Rio de Janeiro JEP: JDK Enhancement Proposals KEM: Key Encapsulation Mechanism LCG: Linear Congruential Generator LWE: Learning With Errors ML-KEM: Module-Lattice-Based Key Encapsulation Mechanism NIST: National Institute of Standards and Technology NRBG: Non-deterministic Random Bit Generator PQC: Post-Quantum Cryptography PRNG: Pseudo Random Number Generator QRNG: Quantum Random Number Generator TRNG: True Random Number Generator

Sumário

1	RESUMO	2
2	ABSTRACT	3
3	LISTA DE ABREVIATURAS	4
	Sumário	4
4	INTRODUÇÃO	7
4.1	Contextualização do Tema	7
4.2	Justificativa/Problema de Pesquisa	7
4.3	Motivação/Hipótese e Ameaça Tecnológica	7
4.4	Objetivos	7
4.5	Metodologia	7
5	FUNDAMENTOS DA ALEATORIEDADE EM COMPUTAÇÃO	8
5.1	Entropia e Fontes de Incerteza	8
5.2	A Semente (Seed) como Elemento Crítico	9
5.3	Definição de Aleatoriedade e Tipos de Geradores Aleatórios	10
5.4	Avaliação Estatística da Aleatoriedade	11
6	QUEBRA DE CRIPTOGRAFIAS	14
6.1	Visão Geral da Quebra de Criptografias	14
6.2	Falhas Históricas de Aleatoriedade	14

6.2.1	Uma avaliação pratica do Dual_EC_DRBG	15
6.3	Vulnerabilidades em Algoritmos Criptográficos	20
7	REVISÃO DOS PROTOCOLOS E PADRÕES DE CRIPTOGRAFIA	22
7.1	Fundamentação da Autoridade e Tipos de Padrões	22
7.1.1	NIST Internal/Interagency Reports (NISTIR)	22
7.1.2	FIPS	22
7.1.2.1	FIPS 204 (ML-DSA)	23
7.1.2.2	FIPS 205 (SLH-DSA)	23
7.1.3	SPs	23
7.1.3.1	FISMA e OMB	24
7.1.3.2	NIST SP 800–53	24
7.2	Metodologia de Seleção	25
7.2.1	Fases de Competição	25
7.3	Manutenção e Substituição de Padrões	25
7.3.1	Ciclo de Vida e Retirada (Withdrawal)	25
8	PLANEJAMENTO PARA A CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)	27
8.1	Contextualização e Gestão de Risco	27
8.1.1	A Ameaça Quântica e o Paradigma “Harvest Now, Decrypt Later”	27
8.1.2	Mapeamento do Risco Quântico	27
8.2	Inventário e Descoberta Criptográfica	27
8.2.1	Estratégias de Descoberta em Redes e Sistemas	27
8.2.2	Adoção do CBOM (Cryptographic Bill of Materials)	27
8.3	Agilidade Criptográfica e Novos Padrões	28
8.3.1	Conceitos de Agilidade e Desafios de Desempenho	28
8.3.2	Os Padrões Pós-Quânticos Finais	28
8.4	Estratégias de Migração e Hibridização	28
8.4.1	Hibridização (Criptografia Clássica e PQC)	28
8.4.2	Assinaturas Baseadas em Hash para Adoção Imediata	28
8.5	Roadmap e Manutenção da Base Criptográfica	29
8.5.1	Cronograma e Descontinuação de Algoritmos Atuais	29
8.5.2	O Papel Contínuo da Entropia	29
9	NIST IR 8547 TRANSIÇÃO PARA A CRIPTOGRAFIA PÓS-QUÂNTICA: ESTRATÉGIAS E CONSIDERAÇÕES	30
9.1	Urgencia Prática e o Modelo de Ameaça	30
9.1.1	Ameaça Harvest now, Decrypt Later	30
9.1.2	Teorema de Mosca e a Linha do Tempo	30

9.2	Novos Padrões e Categorias de Segurança	30
9.2.1	Publicações dos primeiros FIPS PQC	31
9.2.2	Categorias de Segurança Pós-Quântica (1 a 5)	31
9.3	Cronograma de Descontinuação (Deprecation)	31
9.3.1	Transição de Assinaturas Digitais (RSA, ECDSA, EdDSA)	31
9.3.2	Transição de Estabelecimento de Chaves (DH, MQV, RSA)	32
9.4	Estratégias de Transição: Protocolos Híbridos	32
9.4.1	Soluções Híbridas (PQC-Classical)	32
9.4.2	Protocolos Híbridos (TLS, SSH, IPsec)	32
9.4.3	Agilidade Criptográfica em Camadas de Infraestrutura	33
10	CRISTALS KYBER	34
10.1	Introdução	34
10.2	Estrutura do CRYSTALS-Kyber	34
11	CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)	35
11.1	Definição e Objetivos da PQC	35
11.2	Paradigmas Matemáticos da PQC	35
11.3	Criptografia Baseada em Reticulados	35
11.4	Learning With Errors (LWE)	35
11.4.1	Implementação Didática em Java (Demonstração)	35
11.5	Padronização Pós-Quântica	35
12	A TRANSIÇÃO PARA PQC NO ECOSSISTEMA JAVA	36
12.1	Suporte à Criptografia Pós-Quântica no Java	36
12.2	Crypto-Agility	36
12.2.1	Implementação Prática: Demo de Crypto-Agility	36
12.3	Comparativo de Modelos	36
12.3.1	Implementação Prática: Benchmark Clássico vs. Kyber	36
13	DISCUSSÃO E ANÁLISE CRÍTICA	37
13.1	Impacto em Desempenho	37
13.2	Barreiras de Adoção	37
13.3	Implicações Sociais e Éticas	37
14	CONCLUSÃO	38
14.1	Síntese dos Resultados	38
14.2	Resposta ao Problema de Pesquisa	38
14.3	Trabalhos Futuros	38
	REFERÊNCIAS	39

4 Introdução

A onipresença da criptografia na infraestrutura digital moderna (internet, sistemas bancários, IoT e comunicações seguras).

4.1 Contextualização do Tema

Textos

4.2 Justificativa/Problema de Pesquisa

O conflito entre o determinismo computacional e a necessidade de aleatoriedade em sistemas criptográficos.

4.3 Motivação/Hipótese e Ameaça Tecnológica

O impacto da computação quântica — especialmente por meio do Algoritmo de Shor — sobre os modelos atuais de segurança e pseudoaleatoriedade.

4.4 Objetivos

Objetivo Geral: Analisar a evolução dos geradores pseudoaleatórios criptograficamente seguros frente à transição para a criptografia pós-quântica. Objetivos Específicos: Estudar PRNGs e CSPRNGs clássicos Analisar o impacto dos algoritmos quânticos Investigar os novos paradigmas de pseudoaleatoriedade baseados em reticulados Avaliar a adoção desses conceitos no ecossistema Java

4.5 Metodologia

Pesquisa bibliográfica, análise documental de padrões criptográficos e estudo prático no ecossistema Java.

5 FUNDAMENTOS DA ALEATORIEDADE EM COMPUTAÇÃO

5.1 Entropia e Fontes de Incerteza

Captação de eventos físicos imprevisíveis como base para sistemas criptográficos seguros.

Entropia é uma medida da aleatoriedade ou imprevisibilidade dos dados. No contexto da criptografia, a entropia é usada para gerar números aleatórios ou chaves que são essenciais para a comunicação segura e a criptografia. Sem uma boa fonte de entropia, os protocolos criptográficos podem se tornar vulneráveis a ataques que exploram a previsibilidade das chaves geradas.

Na maioria dos sistemas operacionais, a entropia é gerada pela coleta de eventos aleatórios de diversas fontes, como interrupções de hardware, movimentos do mouse, pressionamentos de teclas e atividade do disco. Esses eventos são inseridos em um conjunto de entropia, que é então usado para gerar números aleatórios quando necessário.

Protocolos criptográficos, como SSL/TLS, SSH e IPsec, dependem fortemente da entropia para gerar números aleatórios e chaves para criptografia, autenticação e proteção de integridade. A aleatoriedade desses números é crucial para a segurança da comunicação. Se um atacante conseguir prever os números aleatórios usados em um protocolo criptográfico, ele poderá comprometer a confidencialidade, a integridade ou a autenticidade da comunicação. Se a chave mestra prévia for previsível ou tendenciosa, um atacante poderá interceptar a mensagem criptografada, descriptografá-la e obter acesso às chaves de sessão. Isso permitiria ao atacante espionar a comunicação, modificar os dados ou se passar pelo servidor.

Um tipo de entropia. É a entropia de “Shannon”. Que utiliza um tratamento probabilístico de uma função logarítmica. Sendo sua formula:

$$H(X) = - \sum_{i=1}^n P(x_i) \log_b P(x_i) \quad (5.1)$$

Em que:

- $H(X)$ é a entropia em bits;
- p_i é a probabilidade de ocorrência do resultado i ;
- n é o número total de resultados possíveis.

Uma limitação determinística é em cima de um processador de maquina de estados finitos. Se acaso for utilizado as mesmas variáveis, o resultado permanece inalterado. Onde

se um invasor tiver a certeza da seed de origem da criptografia. Ela por si mesma, não é aleatória. Para evitar tais acontecimentos se faz necessário que o software faça a captação da incerteza do mundo físico.

A entropia deve ter força superior ou igual a segurança do sistema criptográfico. Entropia adicional poder ser necessária para compensar a perda de entropia durante o processo de geração de chaves, mas não necessariamente adiona mais segurança. Ter mais entropia do que a quantidade avaliada é aceitável, ter menos do que o recomendado pode ser fatal para a segurança do sistema criptográfico. O comprimento mínimo depende do mecanismo criptográfico específico e do nível de segurança desejado. A entrada de entropia e a seed resultante devem ser consistentes com a segurança dos dados protegidos pelo consumidor. Em um modelo DRBG a seed e as chaves geradas devem possuir o mesmo nível de segurança, pois no modelo DRBG depende da entropia usada, seguindo o critério de segurança crítico (CSP).

5.2 A Semente (Seed) como Elemento Crítico

Falar sobre esse ponto, pois vai ser utilizado na explicação dos protocolos tanto do funcionamento de verificação do NIST 800-22, do NIST IR 8547 e do NIST IR 7977 por quantico

Uma sequência de bits usada como entrada para um gerador de números pseudoaleatórios (DRBG). A semente é a chave inicial, usada internamente para a concepção do DRBG. Sua entropia deve ser suficiente para garantir a segurança do DRBG. A semente é um elemento crítico, pois determina a sequência de números pseudoaleatórios gerados pelo DRBG. Se a semente for previsível ou tiver baixa entropia, o DRBG pode ser vulnerável a ataques que exploram essa fraqueza. Portanto, é essencial que a semente seja gerada a partir de uma fonte de entropia confiável.

Uma sequência de bits usada como entrada para um mecanismo DRBG. A semente determinará uma parte do interior estado do DRBG, e sua entropia deve ser suficiente para apoiar a força de segurança do DRBG Para obter uma seed suficientemente aleatória. Deve se submeter a uma estimativa de entropia para as saídas da fonte de ruído, baseada na própria fonte da entropia. Essa estimativa é denominada de $H_{\text{submitter}}$. Depois de possuir uma trilha de estimativas, a estimativa de entropia mínima por amostra chamada de H_{original} é determinada. Se o tamanho for superior a 256 bits, ele precisará ser reduzido para menor ou igual a 256 bits.

Se o conjunto de dados não for binário, é necessário uma entropia adicional em bit, denominada de $H_{\text{bitstring}}$ é estimada. O conjunto de dados sequências possui L amostras, cada uma contendo N bits e é considerado uma cadeia de bits de tamanho $L \times N$. Após os primeiros 1.000.000 bits podem vir a serem desconsiderados então $H_{\text{bitstring}}$ é calculada. Tendo como amostra estimada como $N \times H_{\text{bitstring}}$. A estimativa da entropia inicial da

fonte é calculada como $H_{\text{initial}} = \min(H_{\text{original}}, H_{\text{bitstring}})$.

5.3 Definição de Aleatoriedade e Tipos de Geradores Aleatórios

RNG (Random Number Generator) é um dispositivo ou algoritmo que gera uma sequência de números ou símbolos que não possuem nenhum padrão discernível, ou seja, são imprevisíveis. Que utiliza uma fonte de incerteza (ou seja, a fonte de entropia) ao mesmo tempo que faz uso de uma função de processo (processo de destilação) para gerar aleatoriedade. O processo de destilação é uma etapa crucial para exceder qualquer ruptura de segurança na origem da entropia que possa resultar em uma sequência não aleatória. Como a geração de longas sucessões de zeros ou uns, ou mesmo a repetição de um mesmo número, o que pode ser um indicativo de uma fonte de entropia comprometida. Normalmente a fonte de entropia é através de um processo físico, como o ruído térmico, circuito elétrico, o movimento do mouse ou a digitação do teclado, ou os efeitos quânticos de um semicondutor. Múltiplas fontes podem ser utilizadas para esse processo. As saídas de um RNG podem vir a ser utilizadas para um pseudo gerador de números aleatórios (PRNG). A saída de um RNG deve seguir certos critérios de aleatoriedade medidos por testes estatísticos, como os definidos pelo NIST 800-22, para garantir que os números gerados sejam adequadamente aleatórios para uso em criptografia e outras aplicações sensíveis à segurança. Para fins de criptografia, é crucial que os números gerados por um RNG sejam verdadeiramente aleatórios. No entanto, algumas das fontes como data/hora são previsíveis, que combinados com outras fontes de entropia, podem mitigar a previsibilidade. E que ainda pode se tornar deficiente ao passar pelos testes estatísticos. A produção de RNGs de alta qualidade se tornam um recurso oneroso. Tornando improdutivo quando se faz necessário de múltiplas gerações de RNGs. Por isso, a utilização de PRNGs se torna uma alternativa mais viável, pois eles podem gerar grandes quantidades de números pseudoaleatórios a partir de uma semente inicial.

PRNG (Pseudo-Random Number Generator) é um tipo de gerador de números aleatórios que utiliza um algoritmo determinístico para produzir uma sequência de números que aparenta ser aleatória. Ele faz uso de uma semente (seed) inicial para gerar uma sequência de números pseudoaleatórios. Em momentos que se faz necessário uso de imprevisibilidade, a seed se faz necessária ser imprevisível e oriundas e suma de um RNG. Por padrão um PRNG requer majoritariamente de um RNG. Como o PRNG é um algoritmo determinístico, por isso ele leva o nome de pseudoaleatório, pois a sequência de números gerada por um PRNG é completamente determinada pela semente inicial. Como a reprodução de uma sequência de números pseudoaleatórios é possível se a semente for conhecida, somente ela se faz necessária salvar e proteger. De forma cômica, muitos dos valores gerados por um PRNG aparentam ser mais aleatórios do que os números gerados por um RNG. Se sua concepção for bem desenvolvida, cada geração utiliza o valor da anterior por meio de

transformações matemáticas, que acabam introduzindo uma aleatoriedade adicional. Uma série de transformações podem eliminar autocorrelações e padrões, entre a entrada e a saída.

DRBG (Deterministic Random Bit Generator) é um tipo específico de PRNG que é projetado para ser criptograficamente seguro. Ele produz uma sequência de bits que a partir de uma seed inicial, determina uma sequência de bits pseudoaleatórios. A seed para instanciar um DRBG deve ser gerada a partir de uma fonte de entropia confiável, como um RBG (Random Bit Generator), para garantir a segurança do DRBG. Se a seed for protegida e tiver alta entropia, o DRBG pode ser considerado seguro para uso em criptografia. Além da dependência de uma semente de alta entropia, a segurança de um DRBG reside em sua capacidade de manter a Backtracking Resistance e a Prediction Resistance. Conforme o NIST SP 800-90A, esses mecanismos garantem que o comprometimento temporário do estado interno do gerador não resulte na exposição de chaves criptográficas geradas anteriormente ou no colapso da imprevisibilidade dos bits futuros

NRBG (Non-deterministic Random Bit Generator) é um tipo de gerador de números aleatórios que se baseia em processos físicos ou eventos imprevisíveis para gerar números aleatórios. Ao contrário dos DRBGs, que são determinísticos e dependem de uma semente para gerar números pseudoaleatórios, os NRBGs não são determinísticos e não dependem de uma semente. Eles podem usar fontes de entropia, como ruído térmico, fenômenos quânticos ou outros eventos físicos imprevisíveis para gerar números aleatórios.

TRNG (True Random Number Generator) utiliza da entropia de eventos físicos imprevisíveis para gerar números aleatórios ao invés da utilização de algoritmos determinísticos. É normalmente utilizado para gerar chaves criptográficas, Algoritmo de assinatura digital de curva elíptica[ECDSA] ou chaves MAC simétricas, para armazenar e transmitir dados com alta segurança em protocolos criptográficos como o TLS. As chaves geradas por um TRNG são altamente resistentes a ataques de força bruta, pois a entropia de um TRNG é geralmente muito alta, tornando difícil para um atacante adivinhar ou reproduzir as chaves geradas.

5.4 Avaliação Estatística da Aleatoriedade

Existem diversos testes estatísticos que podem ser utilizados em uma sequência para avaliar e comparar com uma sequência verdadeiramente aleatória. A aleatoriedade é uma característica probabilística, de forma que é possível descrever em termos de probabilidade. O resultado dos avaliadores estatísticos, quando baseados em uma sequência de bits verdadeiramente aleatória, é denominada de priori. É capaz de aplicar uma infinidade de testes estatísticos para avaliar a aleatoriedade de uma sequência de bits. Cada um avaliando um aspecto diferente da aleatoriedade, sendo a presença ou ausência de padrões, que sendo identificados seria uma indicação que a sequência não possui as características

aleatórias suficientes. Já que existe uma possibilidade de aplicar uma sequência infinita de testes, nenhum pode ser considerado completo, sendo necessário estabelecer um conjunto de testes estatísticos padronizados para avaliar a aleatoriedade de sequências de bits. E ainda assim devem ser analisados com cuidado para evitar conclusões errôneas sobre a aleatoriedade de uma sequência de bits.

Uma hipótese nula (H_0) é formulada para cada teste estatístico, que geralmente afirma que a sequência de bits é aleatória. Na outra ponta está a hipótese alternativa (H_1), que afirma que a sequência de bits não é aleatória. O teste estatístico é então aplicado à sequência de bits, e um valor de teste é calculado com base nos resultados do teste. Ao final de cada teste se tem uma decisão a ser tomada, que é se rejeitar ou não a hipótese nula.

Para cada distribuição teórica em cima da hipótese nula (H_0) é determinada por meios matemáticos. A partir disso, na distribuição de referência, um valor crítico é determinado longe o suficiente para que a probabilidade de obter um resultado tão extremo quanto o observado seja menor do que um nível de significância predefinido 0.01.

Na realização, se um valor de um teste exceder o valor crítico, a hipótese nula (H_0) é rejeitada. Se o pressuposto da aleatoriedade for verdadeira o valor final da estatística terá uma probabilidade muito baixa de exceder o valor crítico.

Só há duas alternativas de decisão, ou a hipótese nula (H_0) é rejeitada ou não é rejeitada. Se a hipótese nula for rejeitada, isso sugere que a sequência de bits não é aleatória, e que pode haver padrões ou correlações presentes na sequência. Se a hipótese nula (H_0) não for rejeitada, isso sugere que a sequência de bits é aleatória, mas não prova que a sequência é verdadeiramente aleatória.

Erro Tipo 1 ocorre quando a hipótese nula (H_0) é rejeitada, mesmo que seja verdadeira. Isso ocorre quando o teste estatístico indica que a sequência de bits não é aleatória. A probabilidade de um erro do tipo 1 é chamada de nível de significância e é denotada por α . Na criptografia valores comuns para α são 0.01 ou 0.001, o que significa que há uma probabilidade de 1% ou 0.1% de rejeitar a hipótese nula (H_0) quando ela é verdadeira. É esperado que 1 a cada 100 sequências de bits sejam rejeitadas.

Erro do Tipo 2 ocorre quando a hipótese nula (H_0) não é rejeitada, mesmo que seja falsa. Isso ocorre quando o teste estatístico indica que a sequência de bits é aleatória, mesmo que haja padrões ou correlações presentes na sequência. A probabilidade de um erro do tipo 2 é denotada por β . Não há um valor fixo para β , pois depende do teste estatístico específico e da natureza dos padrões ou correlações presentes na sequência de bits e que possui uma infinidade de maneiras de que uma sequência de bits não seja aleatória.

Uma das principais metas da execução de testes estatísticos é minimizar a probabilidade de cometer erros do tipo 2. Diminuindo a probabilidade de ter um gerador ruim aceitar uma sequência de bits como aleatória. O estatístico de teste é usado para calcular um

P-value que resume a força da evidência contra a hipótese nula.

Se $P\text{-value} = 1$, a sequência parece ter aleatoriedade perfeita.

Se $P\text{-value} = 0$, a sequência parece ser completamente não-aleatória.

Se $P\text{-value} \geq \alpha$, a hipótese nula é aceita (a sequência parece ser aleatória).

Se $P\text{-value} < \alpha$, a hipótese nula é rejeitada (a sequência não é aleatória).

O NIST SP 800–22 é um conjunto de testes estatísticos amplamente utilizado para avaliar a aleatoriedade de sequências de bits geradas por geradores de números aleatórios. Sendo ao todo 15 testes, cada um projetado para detectar diferentes tipos de padrões ou falhas na aleatoriedade. Esses testes incluem:

1. Teste de Frequência (monobit)
2. Teste de Frequência dentro de um bloco
3. Teste de Sequências
4. Testes para Maior Sequência de Uns em um bloco
5. Testes de Posto de Matriz Binária
6. Teste da Transformada Discreta de Fourier (Espectral)
7. Teste de Correspondência de Modelos não Sobrepostos
8. Teste de Correspondência de Modelos Sobrepostos
9. Teste "Estatístico Universal" de Maurer
10. Teste de Complexidade Linear
11. Teste Serial
12. Teste de Entropia Aproximada
13. Teste de Somas Cumulativas (Cusums)
14. Teste de Excursões Aleatórias
15. Teste de Variante de Excursões Aleatórias

6 Quebra de criptografias

6.1 Visão Geral da Quebra de Criptografias

A quebra de criptografia refere-se ao processo de comprometer a segurança de um sistema criptográfico, seja por meio da descoberta de vulnerabilidades, exploração de falhas ou desenvolvimento de técnicas que permitem a recuperação de informações protegidas sem autorização. A quebra pode ocorrer devido a falhas na implementação, fraquezas nos algoritmos ou avanços tecnológicos que tornam os métodos de ataque mais eficazes. A evolução da computação, especialmente com o advento da computação quântica, tem levantado preocupações significativas sobre a segurança dos sistemas criptográficos atuais, destacando a necessidade de desenvolver e adotar algoritmos resistentes a ataques futuros.

6.2 Falhas Históricas de Aleatoriedade

Dual_EC_DRBG, um gerador de números pseudoaleatórios que foi suspeito de conter uma backdoor, permitindo que um atacante previsse os números gerados.

DUAL_EC_DRBG (Dual Elliptic Curve Deterministic Random Bit Generator) é um fornecedor de dados pseudoaleatórios para iniciar e continuar a operação criptográfica. Seu uso começou em meados dos anos 2000. Ele utiliza duas curvas elípticas, P e Q , para gerar números pseudoaleatório, que são difíceis de prever o próximo valor ou os anteriores.

Curvas elípticas são uma curva algébrica definida por uma equação do tipo $y^2 = x^3 + ax + b$, onde a e b são constantes que satisfazem a condição de que a curva de não singularidade $4a^3 + 27b^2 \neq 0$. Elas são usadas em criptografia devido à sua estrutura matemática que permite operações eficientes e seguras, como a multiplicação de pontos, que é a base para muitos algoritmos criptográficos.

Utilizada em dispositivos moveis ou servidores que lidam com muitas conexões. Sendo corretamente implementada, é considerada segura quanto outras formas de criptografia. Ela é capaz de combinar de melhor eficiencia com segurança permitindo chaves menores do que as usadas em RSA, por exemplo, para um nível de segurança equivalente. Porém o Dual_EC_DRBG foi amplamente criticado por sua lentidão.

O Dual_EC_DRBG utiliza dois pontos, P e Q , em uma curva elíptica. Os valores pseudoaleatórios são gerados a partir da aritmética desses pontos; especificamente, ao utilizar o ponto P , é possível encontrar o seu dobro, $2P$, através da intersecção da reta tangente com a curva e posterior reflexão em relação ao eixo x . Esse processo de multiplicação escalar é perpetuado até atingir um ponto nP .

O algoritmo funciona utilizando um dado inicial (semente) s_i . O fluxo de geração segue os seguintes passos:

- **Atualização de Estado:** O novo estado interno é gerado ao computar o ponto $s_i P$, onde o valor da coordenada x resultante é definido como $s_{i+1} = x(s_i P)$.
- **Geração de Saída:** Simultaneamente, a saída é gerada através do ponto Q no processo $r_i = x(s_i Q)$.

Por padrão, são descartados os 16 bits mais significativos de r_i para compor a saída final utilizada na criptografia. Em termos de fluxo, o valor $s_i P$ impõe-se como o valor inicial para o próximo ciclo, enquanto $x(s_i Q)$ é o valor de saída. Para a segurança do gerador, não deve ser possível reverter s_i a partir da saída, nem que $s_i Q$ revele informações sobre o estado interno $s_i P$.

A vulnerabilidade do **Dual_EC_DRBG** reside justamente nos 16 bits truncados, que reduzem o espaço de busca para apenas $2^{16} = 65536$ possibilidades, tornando viável um ataque de força bruta para recuperar o ponto original. Caso exista uma relação especial entre os pontos tal que $P = zQ$, um atacante que conheça o escalar z pode deduzir, por meio de propriedades associativas, a seguinte igualdade:

$$z(s_i Q) = s_i(zQ) = s_i P$$

6.2.1 Uma avaliação pratica do Dual_EC_DRBG

Para a validação prática da vulnerabilidade, foi desenvolvida uma Prova de Conceito (PoC) em linguagem Java. A implementação utilizou a biblioteca Bouncy Castle para operações de criptografia de curva elíptica. O código fonte seguiu a estrutura lógica de implementações de referência disponíveis na comunidade de segurança sendo adaptado para demonstrar especificamente a previsibilidade de estados no ambiente Java 21.

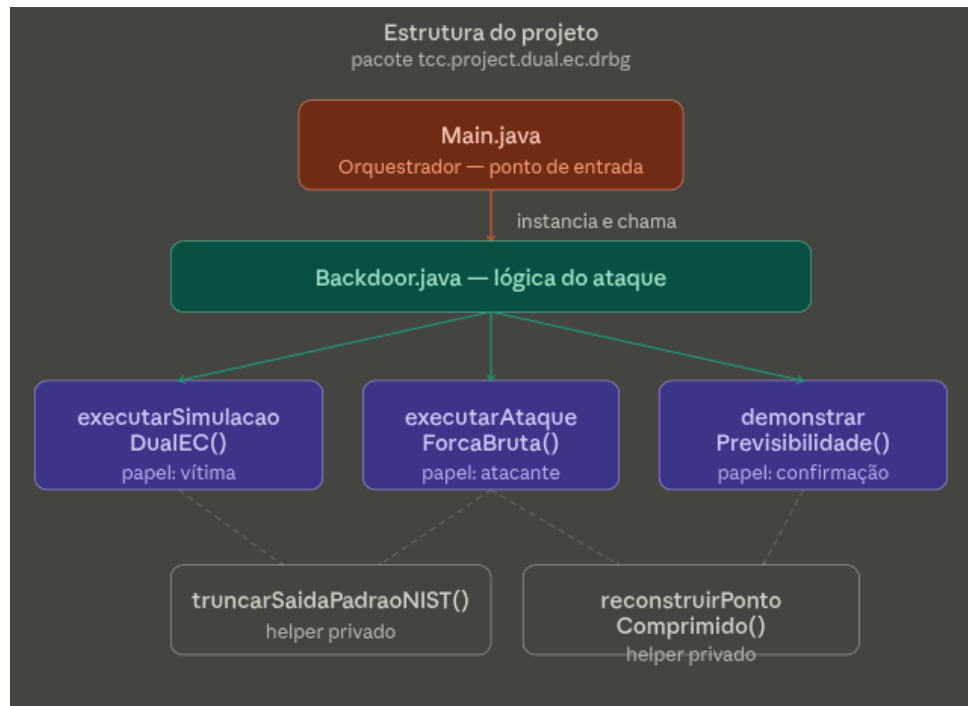
Tabela 1 – Dicionário de Variáveis da Classe Main

Variável	Tipo	Descrição Acadêmica
curve	X9ECParameters	Contém os parâmetros estruturais da curva elíptica NIST P-256.
P	ECPPoint	Ponto gerador base da curva, utilizado para a transição de estados internos (s_{i+1}).
n	BigInteger	A ordem da curva elíptica (número total de pontos no corpo finito).
d	BigInteger	O <i>Backdoor</i> . Escalar secreto tal que $Q = d \cdot P$.
Q	ECPPoint	Ponto público viciado inserido no gerador para permitir a criptoanálise.
e	BigInteger	Inverso multiplicativo de d em relação a n ($d^{-1} \pmod{n}$).
s	BigInteger	Semente (<i>seed</i>) secreta inicial que define a entropia do sistema.
r0Capturado	byte[]	Primeira amostra de saída (240 bits) observada pelo atacante.
s1Recuperado	BigInteger	O segredo interno descoberto após a execução do ataque de força bruta.

Tabela 2 – Dicionário de Métodos e Variáveis da Classe Backdoor

Identificador	Tipo	Descrição Técnica
executarSimulacao	Método	Implementa as funções de transição de estado e saída do Dual_EC_DRBG.
executarAtaque	Método	Algoritmo de busca exaustiva para recuperação de estado via <i>backdoor</i> .
s_state	BigInteger	Representa o estado interno atual (s_i) no ciclo do gerador.
totalTentativas	int	Contador do esforço computacional (máximo de 2^{17} operações).
xCandidate	BigInteger	Coordenada x reconstruída combinando bits adivinhados e bits observados.
compressionPrefix	String	Prefixo (02 ou 03) que resolve a ambiguidade da coordenada y na curva.
s1_candidate	BigInteger	Candidato a estado interno obtido pela aplicação do escalar e sobre o ponto.
truncarSaida	Método	Simula o descarte dos 16 bits mais significativos da coordenada x .
reconstruirPonto	Método	Formata a coordenada x para o padrão de decodificação da Bouncy Castle.

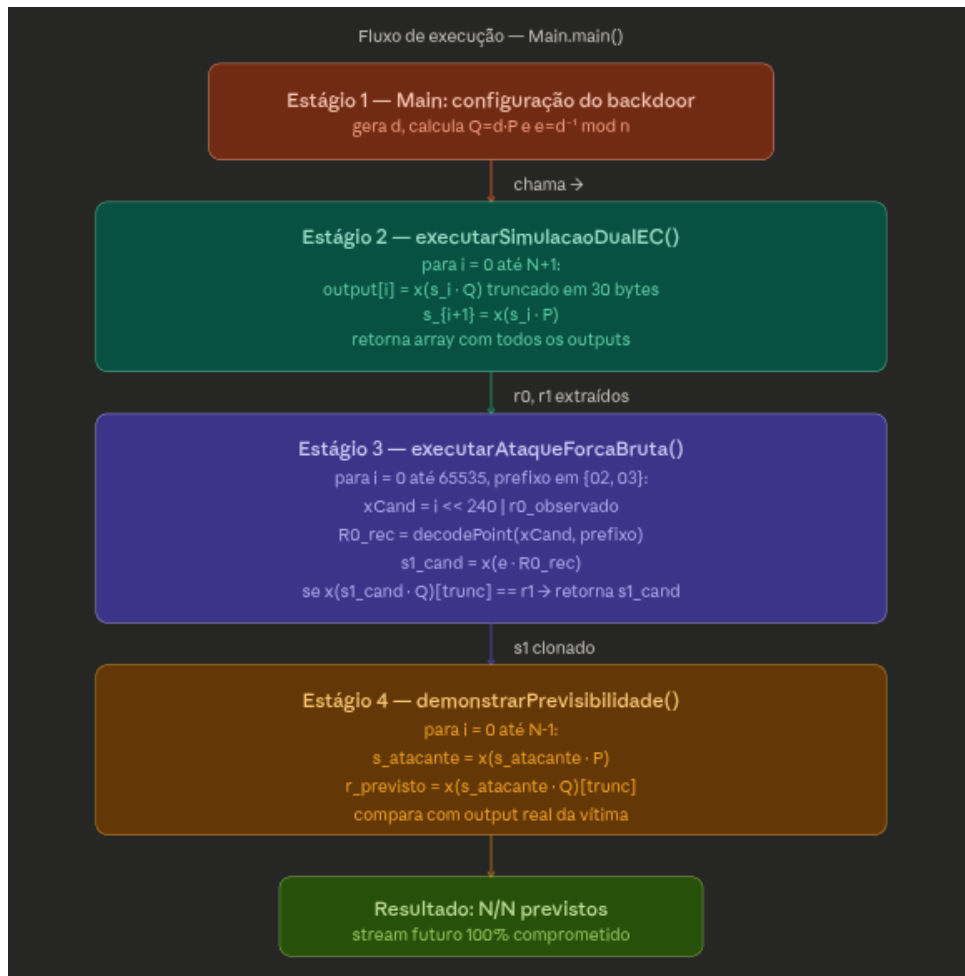
Figura 1 – Diagrama da Simulação do Backdoor do Dual_EC_DRBG



Fonte: Elaborado pelo autor (2026)

Diagrama é uma representação visual do processo de simulação do backdoor do Dual_EC_DRBG. Ele ilustra as etapas envolvidas na geração de números pseudoaleatórios e na execução do ataque de força bruta para recuperar o estado interno. Esse processo foi dividido entre a Main como orquestrador e a classe Backdoor, que contém a lógica de simulação e ataque, além de funções auxiliares. **Main:** Configura os parâmetros da curva elíptica, pontos P e Q, semente inicial e chama os métodos de simulação e ataque. **Backdoor:** Contém o método `executarSimulacaoDualEC` para simular a geração de números pseudoaleatórios e o método `executarAtaqueForcaBruta` para recuperar o estado interno a partir das saídas observadas. Ele também inclui funções auxiliares para reconstruir pontos e truncar saídas conforme o padrão NIST.

Figura 2 – Fluxo da Simulação do Backdoor do Dual_EC_DRBG



Fonte: Elaborado pelo autor (2026)

Um fluxo de execução é a ordem exata em que as instruções de um programa são processadas pelo computador. Diferente do fluxo original de funcionamento do DUAL_EC_DRBG, e como atacantes utilizam sua fragilidade. Na simulação todas as etapas foram implementadas e gerenciadas ao mesmo tempo, se conversando. Na realidade, essas funções e etapas não se conversam. O ataque começa com R_0 e R_1 (os dois outputs observados). O atacante não olha para R_2 durante o processo de quebra — ele prevê R_2 de forma independente, e só ao final compara com o valor real para confirmar que acertou. Isso é idêntico ao que aconteceria na vida real: o servidor TLS emite R_0 num handshake, R_1 num pacote seguinte, e R_2 em outro pacote posterior — todos trafegam pela rede, e o atacante os captura em sequência. R_2 já chegou pela rede antes mesmo de o atacante terminar o brute-force dos 16 bits.

Figura 3 – Simulação do Ataque de Força Bruta Teste 1

```

Projeto > QuebraCripto > src > main > java > tcc > project > dual > ec > drbg > - : Main.java > ...
9
You: 5 minutos ago | 1 author (You)
10 public class Main {
11     Run [Debug]
12     public static void main(String[] args) {
13         Backdoor backdoor = new Backdoor();
14         XECParameters curve = NISTNamedCurves.getByName("P-256");
15         ECPPoint P = curve.getG();
16         BigInteger n = curve.getN();
17
18         BigInteger d = new BigInteger(256, new SecureRandom()).mod(n);
19         ECPPoint Q = P.multiply(d).normalize();
20         BigInteger e = d.modInverse(n);
21
22         System.out.println("=== SIMULACAO DUAL_EC_DRBG - PREVISAO DE GERACAO ===\n");
23
24         final int OUTPUTS_FUTUROS = 10;
25         BigInteger s = new BigInteger(256, new SecureRandom()).mod(n);
26
27         BigInteger[] estadosReais = new BigInteger(OUTPUTS_FUTUROS + 2);
28
29         byte[] outputResultante = backdoor.executarSimulacaoDualEC(OUTPUTS_FUTUROS, curve, P, Q, s, estadosReais);
30
31         byte[] rRCapturado = outputResultante[0];
32         byte[] rICapturado = outputResultante[1];
33
34         System.out.println("... OUTPUTS OBSERVADOS PELO ATACANTE ...");
35         System.out.println("R0 (capturado): " + Hex.toHexString(rRCapturado));
36         System.out.println("R1 (capturado): " + Hex.toHexString(rICapturado));
37         System.out.println();
38
39         BigInteger sRecuperado = backdoor.executarAtaqueForcaBruta(rRCapturado, rICapturado, curve, Q, e);
40
41         backdoor.demonstrarPrevisibilidade(OUTPUTS_FUTUROS, sRecuperado, P, Q, outputResultante);
42     }
43 }
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
932
933
934
935
936
937
938
939
940
941
942
943
944
945
946
947
948
949
950
951
952
953
954
955
956
957
958
959
960
961
962
963
964
965
966
967
968
969
970
971
972
973
974
975
976
977
978
979
980
981
982
983
984
985
986
987
988
989
990
991
992
993
994
995
996
997
998
999
1000
1001
1002
1003
1004
1005
1006
1007
1008
1009
1010
1011
1012
1013
1014
1015
1016
1017
1018
1019
1020
1021
1022
1023
1024
1025
1026
1027
1028
1029
1030
1031
1032
1033
1034
1035
1036
1037
1038
1039
1040
1041
1042
1043
1044
1045
1046
1047
1048
1049
1050
1051
1052
1053
1054
1055
1056
1057
1058
1059
1060
1061
1062
1063
1064
1065
1066
1067
1068
1069
1070
1071
1072
1073
1074
1075
1076
1077
1078
1079
1080
1081
1082
1083
1084
1085
1086
1087
1088
1089
1090
1091
1092
1093
1094
1095
1096
1097
1098
1099
1100
1101
1102
1103
1104
1105
1106
1107
1108
1109
1110
1111
1112
1113
1114
1115
1116
1117
1118
1119
1120
1121
1122
1123
1124
1125
1126
1127
1128
1129
1130
1131
1132
1133
1134
1135
1136
1137
1138
1139
1140
1141
1142
1143
1144
1145
1146
1147
1148
1149
1150
1151
1152
1153
1154
1155
1156
1157
1158
1159
1160
1161
1162
1163
1164
1165
1166
1167
1168
1169
1170
1171
1172
1173
1174
1175
1176
1177
1178
1179
1180
1181
1182
1183
1184
1185
1186
1187
1188
1189
1190
1191
1192
1193
1194
1195
1196
1197
1198
1199
1200
1201
1202
1203
1204
1205
1206
1207
1208
1209
1210
1211
1212
1213
1214
1215
1216
1217
1218
1219
1220
1221
1222
1223
1224
1225
1226
1227
1228
1229
1230
1231
1232
1233
1234
1235
1236
1237
1238
1239
1240
1241
1242
1243
1244
1245
1246
1247
1248
1249
1250
1251
1252
1253
1254
1255
1256
1257
1258
1259
1260
1261
1262
1263
1264
1265
1266
1267
1268
1269
1270
1271
1272
1273
1274
1275
1276
1277
1278
1279
1280
1281
1282
1283
1284
1285
1286
1287
1288
1289
1290
1291
1292
1293
1294
1295
1296
1297
1298
1299
1300
1301
1302
1303
1304
1305
1306
1307
1308
1309
1310
1311
1312
1313
1314
1315
1316
1317
1318
1319
1320
1321
1322
1323
1324
1325
1326
1327
1328
1329
1330
1331
1332
1333
1334
1335
1336
1337
1338
1339
1340
1341
1342
1343
1344
1345
1346
1347
1348
1349
1350
1351
1352
1353
1354
1355
1356
1357
1358
1359
1360
1361
1362
1363
1364
1365
1366
1367
1368
1369
1370
1371
1372
1373
1374
1375
1376
1377
1378
1379
1380
1381
1382
1383
1384
1385
1386
1387
1388
1389
1390
1391
1392
1393
1394
1395
1396
1397
1398
1399
1400
1401
1402
1403
1404
1405
1406
1407
1408
1409
1410
1411
1412
1413
1414
1415
1416
1417
1418
1419
1420
1421
1422
1423
1424
1425
1426
1427
1428
1429
1430
1431
1432
1433
1434
1435
1436
1437
1438
1439
1440
1441
1442
1443
1444
1445
1446
1447
1448
1449
1450
1451
1452
1453
1454
1455
1456
1457
1458
1459
1460
1461
1462
1463
1464
1465
1466
1467
1468
1469
1470
1471
1472
1473
1474
1475
1476
1477
1478
1479
1480
1481
1482
1483
1484
1485
1486
1487
1488
1489
1490
1491
1492
1493
1494
1495
1496
1497
1498
1499
1500
1501
1502
1503
1504
1505
1506
1507
1508
1509
1510
1511
1512
1513
1514
1515
1516
1517
1518
1519
1520
1521
1522
1523
1524
1525
1526
1527
1528
1529
1530
1531
1532
1533
1534
1535
1536
1537
1538
1539
1540
1541
1542
1543
1544
1545
1546
1547
1548
1549
1550
1551
1552
1553
1554
1555
1556
1557
1558
1559
1560
1561
1562
1563
1564
1565
1566
1567
1568
1569
1570
1571
1572
1573
1574
1575
1576
1577
1578
1579
1580
1581
1582
1583
1584
1585
1586
1587
1588
1589
1590
1591
1592
1593
1594
1595
1596
1597
1598
1599
1600
1601
1602
1603
1604
1605
1606
1607
1608
1609
1610
1611
1612
1613
1614
1615
1616
1617
1618
1619
1620
1621
1622
1623
1624
1625
1626
1627
1628
1629
1630
1631
1632
1633
1634
1635
1636
1637
1638
1639
1640
1641
1642
1643
1644
1645
1646
1647
1648
1649
1650
1651
1652
1653
1654
1655
1656
1657
1658
1659
1660
1661
1662
1663
1664
1665
1666
1667
1668
1669
1670
1671
1672
1673
1674
1675
1676
1677
1678
1679
1680
1681
1682
1683
1684
1685
1686
1687
1688
1689
1690
1691
1692
1693
1694
1695
1696
1697
1698
1699
1700
1701
1702
1703
1704
1705
1706
1707
1708
1709
1710
1711
1712
1713
1714
1715
1716
1717
1718
1719
1720
1721
1722
1723
1724
1725
1726
1727
1728
1729
1730
1731
1732
1733
1734
1735
1736
1737
1738
1739
1740
1741
1742
1743
1744
1745
1746
1747
1748
1749
1750
1751
1752
1753
1754
1755
1756
1757
1758
1759
1760
1761
1762
1763
1764
1765
1766
1767
1768
1769
1770
1771
1772
1773
1774
1775
1776
1777
1778
1779
1780
1781
1782
1783
1784
1785
1786
1787
1788
1789
1790
1791
1792
1793
1794
1795
1796
1797
1798
1799
1800
1801
1802
1803
1804
1805
1806
1807
1808
1809
1810
1811
1812
1813
1814
1815
1816
1817
1818
1819
1820
1821
1822
1823
1824
1825
1826
1827
1828
1829
1830
1831
1832
1833
1834
1835
1836
1837
1838
1839
1840
1841
1842
1843
1844
1845
1846
1847
1848
1849
1850
1851
1852
1853
1854
1855
1856
1857
1858
1859
1860
1861
1862
1863
1864
1865
1866
1867
1868
1869
1870
1871
1872
1873
1874
1875
1876
1877
1878
1879
1880
1881
1882
1883
1884
1885
1886
1887
1888
1889
1890
1891
1892
1893
1894
1895
1896
1897
1898
1899
1900
1901
1902
1903
1904
1905
1906
1907
1908
1909
1910
1911
1912
1913
1914
1915
1916
1917
1918
1919
1920
1921
1922
1923
1924
1925
1926
1927
1928
1929
1930
1931
1932
1933
1934
1935
1936
1937
1938
1939
1940
1941
1942
1943
1944
1945
1946
1947
1948
1949
1950
1951
1952
1953
1954
1955
1956
1957
1958
1959
1960
1961
1962
1963
1964
1965
1966
1967
1968
1969
1970
1971
1972
1973
1974
1975
1976
1977
1978
1979
1980
1981
1982
1983
1984
1985
1986
1987
1988
1989
1990
1991
1992
1993
1994
1995
1996
1997
1998
1999
2000
2001
2002
2003
2004
2005
2006
2007
2008
2009
2010
2011
2012
2013
2014
2015
2016
2017
2018
2019
2020
2021
2022
2023
2024
2025
2026
2027
2028
2029
2030
2031
2032
2033
2034
2035
2036
2037
2038
2039
2040
2041
2042
2043
2044
2045
2046
2047
2048
2049
2050
2051
2052
2053
2054
2055
2056
2057
2058
2059
2060
2061
2062
2063
2064
2065
2066
2067
2068
2069
2070
2071
2072
2073
2074
2075
2076
2077
2078
2079
2080
2081
2082
2083
2084
2085
2086
2087
2088
2089
2090
2091
2092
2093
2094
2095
2096
2097
2098
2099
2100
2101
2102
2103
2104
2105
2106
2107
2108
2109
2110
2111
2112
2113
2114
2115
2116
2117
2118
2119
2120
2121
2122
2123
2124
2125
2126
2127
2128
2129
2130
2131
2132
2133
2134
2135
2136
2137
2138
2139
2140
2141
2142
2143
2144
2145
2146
2147
2148
2149
2150
2151
2152
2153
2154
2155
2156
2157
2158
2159
2160
2161
2162
2163
2164
2165
2166
2167
2168
2169
2170
2171
2172
2173
2174
2175
2176
2177
2178
2179
2180
2181
2182
2183
2184
2185
2186
2187
2188
2189
2190
2191
2192
2193
2194
2195
2196
2197
2198
2199
2200
2201
2202
2203
2204
2205
2206
2207
2208
2209
2210
2211
2212
2213
2214
2215
2216
2217
2218
2219
2220
2221
2222
2223
2224
2225
2226
2227
2228
2229
2230
2231
2232
2233
2234
2235
2236
2237
2238
2239
2240
2241
2242
2243
2244
2245
2246
2247
2248
2249
2250
2251
2252
2253
2254
2255
2256
2257
2258
2259
2260
2261
2262
2263
2264
2265
2266
2267
2268
2269
2270
2271
2272
2273
2274
2275
2276
2277
2278
2279
2280
2281
2282
2283
2284
2285
2286
2287
2288
2289
2290
2291
2292
2293
2294
2295
2296
2297
2298
2299
2300
2301
2302
2303
2304
2305
2306
2307
2308
2309
2310
2311
2312
2313
2314
2315
2316
2317
2318
2319
2320
2321
2322
2323
2324
2325
2326
2327
2328
2329
2330
2331
2332
2333
2334
2335
2336
2337
2338
2339
2340
2341
2342
2343
2344
2345
2346
2347
2348
2349
2350
2351
2352
2353
2354
2355
2356
2357
2358
2359
2360
2361
2362
2363
2364
2365
2366
2367
2368
2369
2370
2371
2372
2373
2374
2375
2376
2377
2378
2379
2380
2381
2382
2383
2384
2385
2386
2387
2388
2389
2390
2391
2392
2393
2394
2395
2396
2397
2398
2399
2400
2401
2402
2403
2404
2405
2406
2407
2408
2409
2410
2411
2412
2413
2414
2415
2416
2417
2418
2419
2420
2421
2422
2423
2424
2425
2426
2427
2428
2429
2430
2431
2432
2433
2434
2435
2436
2437
2438
2439
2440
2441
2442
2443
2444
2445
2446
2447
2448
2449
2450
2451
2452
2453
2454
2455
2456
2457
2458
2459
2460
2461
2462
2463
2464
2465
2466
2467
2468
2469
2470
2471
2472
2473
2474
2475
2476
2477
2478
2479
2480
2481
2482
2483
2484
2485
2486
2487
2488
2489
2490
2491
2492
2493
2494
2495
2496
2497
2498
2499
2500
2501
2502
2503
2504
2505
2506
2507
2508
2509
2510
2511
2512
2513
2514
2515
2516
2517
2518
2519
2520
2521
2522
2523
2524
2525
2526
2527
2528
2529
2530
2531
2532
2533
2534
2535
2536
2537
2538
2539
2540
2541
2542
2543
2544
2545
2546
2547
2548
2549
2550
2551
2552
2553
2554
2555
2556
2557
2558
2559
2560
2561
2562
2563
2564
2565
2566
2567
2568
2569
2570
2571
2572
2573
2574
2575
2576
2577
2578
2579
2580
2581

```

Figura 4 – Simulação do Ataque de Força Bruta Teste 2

```

10 public class Main {
11     public static void main(String[] args) {
12         Backdoor backdoor = new Backdoor();
13         X9ECParameters curve = NISTNamedCurves.getByName("P-256");
14         ECPublicKey P = curve.getG();
15         BigInteger n = curve.getN();
16         BigInteger d = new BigInteger(256, new SecureRandom()).mod(n);
17         ECPublicKey Q = P.multiply(d).normalize();
18         BigInteger e = d.modInverse(n);
19         System.out.println("=== SIMULACAO DUAL_EC_DRBG - PREVISÃO DE GERACAO ===\n");
20         final int OUTPUTS_FUTUROS = 10;
21         BigInteger s = new BigInteger(256, new SecureRandom()).mod(n);
22         BigInteger[] estadosReais = new BigInteger(OUTPUTS_FUTUROS + 2);
23         byte[] outputResultado = backdoor.executarSimulacaoDualEC(OUTPUTS_FUTUROS, curve, P, Q, s, estadosReais);
24         byte[] rCapturado = outputResultado[0];
25         byte[] r1Capturado = outputResultado[1];
26         System.out.println("--- OUTPUTS OBSERVADOS PELO ATACANTE ---");
27         System.out.println("R0 (capturado): " + Hex.toHexString(rCapturado));
28         System.out.println("R1 (capturado): " + Hex.toHexString(r1Capturado));
29         System.out.println();
30         BigInteger sRecuperado = backdoor.executarAtaqueForçaBruta(rCapturado, r1Capturado, curve, Q, e);
31         backdoor.demonstrarPrevisibilidade(OUTPUTS_FUTUROS, sRecuperado, P, Q, outputResultado);
32     }
33 }

```

```

j@jenopos:~/Documents/Faeterj/TCCFaeterjPetrópolis$ cd /home/jen/Documents/Faeterj/TCCFaeterjPetrópolis ; /usr/bin/env /usr/lib/jvm/java-21-openjdk-amd64/bin/java @/tmp/cp_3r5o3hg8sjkac
=== SIMULACAO DUAL_EC_DRBG - PREVISÃO DE GERACAO ===

--- OUTPUTS OBSERVADOS PELO ATACANTE ---
R0 (capturado): c98bedd573a9d53f629d1b52bed733deb78e48c2ae818bdfb8c38df010
R1 (capturado): 3d4c7021972dc64b2e1818c2d94569377a8cf67c9597912bad8c7958c2b

--- EXECUTANDO CRIPTOMALISE (Brute-force 16-bits) ---
[!] Estado interno s1 sincronizado com sucesso!
[!] Esforço computacional: 104.265 tentativas.

--- PREDIÇÃO DE FLUXO DE DADOS (STREAM PREDICTION) ---
Output Valor Previsto pelo Atacante Status
R2 3341bcd7188dc1458e378bf56ff15c7ae415f79bdc2012b05d471fe79b1 [CONFIRMADO]
R3 91608b1354a6d8a7f525a272ac23223a6d9d9d922172d0adfe223080c [CONFIRMADO]
R4 67ece1669e891da8321e50e74d267495fc57b753d7d5430247f0e5719a8c [CONFIRMADO]
R5 67b77a14a72db7a8877fcf435abc767867cd876c48befd775ce7d6d6f6 [CONFIRMADO]
R6 78a353ca4f63868272021644deef1987b28ff7f1a99efaf576cd015073a2 [CONFIRMADO]
R7 16d901c58ed435afe5daccb700094ba4c192eaa79b8bdab6f11d272aa [CONFIRMADO]
R8 fcc8a8665f514e492db16fe929b7348208eb95c79c86857db5e3195d4d3 [CONFIRMADO]
R9 d34f4e07c54cf6a8a32b4672f6e74db214682b6e4e9b311e4b3960f7f [CONFIRMADO]
R10 90b849e2be5b086f38c82733b5a19982cef6e2043709314580e441120a0 [CONFIRMADO]
R11 78d628f7e1ebf5993dc4e61c6ee0b7b36ce6124448bc61fd39a3a4b7fc [CONFIRMADO]

Resultado da Predição: 10/10 acertos.

```

Fonte: Elaborado pelo autor (2026)

Apesar de o truncamento especificado pelo padrão NIST SP 800-90A remover apenas 16 bits da coordenada x , o custo efetivo do ataque de recuperação de estado é da ordem de 2^{17} multiplicações escalares. Isso ocorre porque, para cada candidato reconstruído de x , é necessário considerar ambas as possíveis coordenadas y , correspondentes às soluções par e ímpar da equação da curva elíptica. Formalmente, o custo total pode ser expresso como:

$$2^{16} \times 2 = 2^{17}$$

No experimento realizado, observou-se que a sincronização do estado exigiu 104.265 tentativas, valor consistente com o limite teórico máximo de 131.072 operações.

6.3 Vulnerabilidades em Algoritmos Criptográficos

Algoritmo de grover. capaz de reduzir a força das entropias das seed pela metade: <https://learn.microsoft.com/es-es/azure/quantum/concepts-grovers> Algoritmo de Grover e a Semente: Explique que o ataque de Grover não "quebra" a matemática do AES ou da Seed, mas reduz a busca exaustiva. Se você usa uma semente de 128 bits, para um computador quântico ela tem o esforço de apenas 2^{64} . Por isso, o NIST IR 7977 exige o dobro de bits (256). Algoritmo de Shor: Este é o "assassino" do RSA e da Curva Elíptica. Enquanto o Grover reduz a força, o Shor aniquila o RSA completamente. É a razão principal da existência da Criptografia Pós-Quântica (PQC).

Colisões em SHA-1: Cite o projeto SHAttered (Google), que provou na prática que o SHA-1 é inseguro ao gerar dois arquivos PDF diferentes com o mesmo hash.

7 Revisão dos protocolos e padrões de criptografia

O NIST utiliza vários documentos para estabelecer os protocolos e padrões de criptografia, cada um com um propósito específico. Sendo comumente publicados em três categorias principais: FIPS (Federal Information Processing Standards), SPs (Special Publications) e IRs (Interagency Reports). Esses documentos são desenvolvidos para garantir a segurança e a integridade dos sistemas de informação, fornecendo diretrizes claras para a implementação de algoritmos criptográficos e práticas de segurança.

Vemos cada vez mais o crescimento do uso de computadores quânticos de forma substancial, o que tem levantando uma forte necessidade de desenvolver e padronizar algoritmos de criptografia pós-quântica (PQC) para proteger os dados contra ataques futuros. Pois nesse ritmo muitos criptossistemas atualmente considerados seguros entraram em fase de risco, incluindo sistemas de assinaturas digitais baseados em fatoração, logaritmos discretos e curvas elípticas(1). Em causa disso, teve uma intensidade das pesquisas em criptografia pós-quântica, resultando em uma variedade de esquemas candidatos para criptografia de chave pública, assinaturas digitais e funções de hash resistentes a ataques quânticos(1).

7.1 Fundamentação da Autoridade e Tipos de Padrões

7.1.1 NIST Internal/Interagency Reports (NISTIR)

Os documentos IRs são relatórios internos ou interagências que fornecem informações detalhadas sobre pesquisas, análises e avaliações relacionadas à criptografia(2). Eles documentam resultados de estudos e experimentos, servindo como fonte para pesquisadores sobre desafios e avanços na área(2).

7.1.2 FIPS

Os documentos FIPS são padrões de processamento de informações federais que estabelecem requisitos específicos para algoritmos criptográficos e práticas de segurança(2). Eles são desenvolvidos para garantir a interoperabilidade e a segurança dos sistemas de informação utilizados pelo governo dos Estados Unidos(2). Os FIPS são amplamente adotados por organizações governamentais e privadas como referência para a implementação de criptografia segura(2). Esses padrões abrangem uma variedade de tópicos, incluindo algoritmos de criptografia simétrica e assimétrica, funções de hash, e protocolos de segurança(2).

7.1.2.1 FIPS 204 (ML-DSA)

ML-DSA (Module-Lattice-Based Digital Signature Algorithm) é um padrão para assinaturas digitais pós-quânticas(3). Ele se baseia no CRYSTALS-Dilithium, onde se faz uso de problemas reticulados modulares (Module-LWE e Module-SIS)(3). Para cada nível de segurança o ML-DSA oferece níveis de proteção diferentes, sendo:(3)

- ML-DSA-44: Nível de Segurança de 128 bits para recursos limitados.
- ML-DSA-64: Nível de Segurança de 192 bits recomendado para a maioria dos casos.
- ML-DSA-84: Nível de Segurança de 256 bits longo prazo e alta segurança.

(3).

O ML-DSA é considerado suficientemente seguro e fortemente infalsificável, mesmo frente a ataques de computadores quânticos(3). Além de demonstrar a propriedade de não repúdio, ele foi desenvolvido de forma que, mesmo que o atacante conheça parte da chave privada, não consiga forjar uma assinatura adicional(3). A segurança baseia-se nos problemas LWE (Learning With Errors) e SIS (Short Integer Solution), expressos matematicamente como $As + e = b$ e $Ax \equiv 0 \pmod{q}$ (3).

A transição do CRYSTALS-Dilithium para o padrão final focou no fortalecimento da segurança(3):

- **Ajuste de Comprimento de Bits:** O comprimento de μ e ρ' foi aumentado para **512** bits.
- **Segurança de Assinatura:** Introdução de uma variante protegida utilizando a string ***rnd*** de **256** bits.

(3)

7.1.2.2 FIPS 205 (SLH-DSA)

SLH-DSA é um padrão para assinaturas digitais sem estado baseado em hash, fundamentado no SPHINCS+(4). A segurança “sem estado” é alcançada através de uma hiperárvore composta por camadas de árvores XMSS, integrando também os esquemas FORS e WOTS+(4).

7.1.3 SPs

Os documentos SPs são publicações especiais que fornecem diretrizes e recomendações para a implementação de algoritmos e práticas de segurança(2). Eles abordam tópicos como gerenciamento de chaves e avaliação de segurança(2).

7.1.3.1 FISMA e OMB

A FISMA estabelece o marco para a gestão da segurança em agências federais⁽²⁾. O OMB coordena a implementação dessas políticas e supervisiona a gestão de tecnologia da informação do governo⁽²⁾.

7.1.3.2 NIST SP 800–53

O NIST SP 800–53 fornece um catálogo abrangente de controles de segurança para sistemas federais⁽⁵⁾. O documento organiza os controles em 20 famílias.⁽⁵⁾

- AC (Access Control)
- AT (Awareness and Training)
- AU (Audit and Accountability)
- CA (Security Assessment and Authorization)
- CM (Configuration Management)
- CP (Contingency Planning)
- IA (Identification and Authentication)
- IR (Incident Response)
- MA (Maintenance)
- MP (Media Protection)
- PE (Physical and Environmental Protection)
- PL (Planning)
- PM (Program Management)
- PS (Personnel Security)
- PT (PII Processing and Transparency)
- RA (Risk Assessment)
- SA (System and Services Acquisition)
- SC (System and Communications Protection)
- SI (System and Information Integrity)
- SR (Supply Chain Risk Management)

(5)

7.2 Metodologia de Seleção

O NIST utiliza competições abertas como estratégia para padronizar primitivas criptográficas de última geração, envolvendo a comunidade internacional de pesquisa em um processo transparente e colaborativo(2). Pesquisadores do mundo inteiro podem participar ativamente, seja analisando requisitos, publicando estudos ou propondo algoritmos candidatos(2). Os autores selecionados recebem reconhecimento, mas abrem mão de direitos de propriedade intelectual para assegurar o uso livre de royalties(2). Durante o processo, o NIST estabelece critérios, promove workshops e divulga relatórios justificando as decisões de cada rodada, permitindo que a comunidade foque nos algoritmos mais promissores(2). Essa abordagem é especialmente eficaz quando não há consenso sobre a melhor solução ou quando novos esquemas exigem ampla criptoanálise(2).

7.2.1 Fases de Competição

Um processo típico de competição envolve chamadas públicas para requisitos, conferências de candidatos para revisar resultados de pesquisa (criptoanálise e desempenho) e “rodadas” de eliminação que permitem à comunidade focar esforços nos candidatos mais promissores até a seleção final(2).

O Processo de Padronização de Criptografia Pós-Quântica do NIST, iniciado em 2016, seguiu um modelo de competição pública dividido em rodadas de eliminação para selecionar algoritmos de assinaturas digitais e estabelecimento de chaves. A primeira rodada contou com 69 candidatos que atenderam aos critérios mínimos, seguidos por uma seleção de 26 algoritmos para a segunda rodada em 2019, baseada em análise de desempenho e feedback da comunidade. A terceira rodada, iniciada em 2020, focou em sete finalistas e oito suplentes, priorizando uma análise profunda da segurança teórica, evidências empíricas e avaliação comparativa para determinar os padrões finais.(1).

7.3 Manutenção e Substituição de Padrões

7.3.1 Ciclo de Vida e Retirada (Withdrawal)

Os padrões são revisados regularmente, com os FIPS sendo avaliados pelo menos a cada cinco anos(2). O processo de manutenção inclui a atualização ou a retirada do padrão, que pode ocorrer via ‘sunsetting’(2).

O NIST possui algumas etapas para a revisão e retirada de padrões, sendo eles:

- **Accepted:** O padrão em questão não possui riscos conhecidos.
- **Deprecated:** O padrão apresenta riscos conhecidos, mas ainda é considerado seguro para uso.

- **Legacy use:** O padrão pode somente ser usado em processamento de informações protegidas.
- **Disallowed:** O padrão não é mais considerado seguro e não deve ser usado.

(6).

O sunseting é um processo de retirada planejada, onde o NIST anuncia a descontinuação de um padrão com antecedência, permitindo que as organizações se preparem para a transição(6). Durante esse período, o padrão pode ser marcado como “deprecated” ou “legacy use”, indicando que ele ainda pode ser utilizado, mas com recomendações para migração futura(6).

8 Planejamento para a Criptografia Pós-Quântica (PQC)

8.1 Contextualização e Gestão de Risco

Esta seção introduz o problema e explica por que a transição deve ser planejada imediatamente, abordando o cenário de risco sob a ótica organizacional.

8.1.1 A Ameaça Quântica e o Paradigma “Harvest Now, Decrypt Later”

Conteúdo: Explicação sobre como adversários já estão coletando tráfego cifrado atual para quebrar a criptografia assim que computadores quânticos criptograficamente relevantes (CRQC) estiverem disponíveis.

Documento indicado: *NIST SP 1800-38A (Executive Summary)*. Fornece o panorama do problema e a urgência da migração sob a perspectiva do NCCoE.

8.1.2 Mapeamento do Risco Quântico

Conteúdo: Como integrar a ameaça quântica nos processos de gestão de risco cibernético da organização.

Documento indicado: *NIST CSWP 48 (Cybersecurity White Paper)*. Relaciona a migração PQC com as práticas do *NIST Cybersecurity Framework (CSF)*.

8.2 Inventário e Descoberta Criptográfica

Antes de migrar, uma organização precisa saber o que possui. Esta seção detalha as metodologias para rastrear o uso atual de criptografia.

8.2.1 Estratégias de Descoberta em Redes e Sistemas

Conteúdo: Métodos e ferramentas para varrer infraestruturas, encontrar chaves embutidas em código, protocolos obsoletos e certificados ocultos.

Documento indicado: *NIST SP 1800-38B (Discovery for PQC Migration)*. Fornece cenários práticos e arquiteturas de referência para a fase de descoberta.

8.2.2 Adoção do CBOM (Cryptographic Bill of Materials)

Conteúdo: O conceito de catalogar a criptografia de forma padronizada para monitorar vulnerabilidades em cadeias de suprimentos de software.

Documento indicado: *NIST SP 1800-38B*. Aborda diretamente como gerar e manter inventários de ativos criptográficos.

8.3 Agilidade Criptográfica e Novos Padrões

Aborda o planejamento arquitetural necessário para facilitar atualizações e apresenta as novas ferramentas de proteção.

8.3.1 Conceitos de Agilidade e Desafios de Desempenho

Conteúdo: O que significa projetar um sistema ágil e quais são os impactos reais na rede (latência, tamanho de chaves, largura de banda) ao trocar os algoritmos.

Documento indicado: *NIST SP 1800-38C (Interoperability and Performance)*. Apresenta casos de uso reais e testes de impacto.

8.3.2 Os Padrões Pós-Quânticos Finais

Conteúdo: A especificação técnica e a indicação de uso dos algoritmos selecionados.
Documentos indicados:

- **FIPS 203 (ML-KEM):** Para troca de chaves criptográficas.
- **FIPS 204 (ML-DSA) e FIPS 205 (SLH-DSA):** Para assinaturas digitais.
- **NIST IR 8413:** Para critérios técnicos do Round 3.

8.4 Estratégias de Migração e Hibridização

Foca na parte prática e operacional da transição.

8.4.1 Hibridização (Criptografia Clássica e PQC)

Conteúdo: A abordagem recomendada de usar algoritmos clássicos em conjunto com PQC durante o período de transição.

Documento indicado: *NIST SP 1800-38C*. Discute os protocolos que suportam negociação híbrida.

8.4.2 Assinaturas Baseadas em Hash para Adoção Imediata

Conteúdo: Uso de algoritmos de assinatura que já são considerados seguros contra ataques quânticos, úteis para validar firmware.

Documento indicado: *NIST SP 800-208*. Padrões stateful hash-based (LMS e XMSS).

8.5 Roadmap e Manutenção da Base Criptográfica

Conclui o planejamento com prazos normativos e a importância de elementos basilares da criptografia.

8.5.1 Cronograma e Descontinuação de Algoritmos Atuais

Conteúdo: Prazos para que algoritmos de chaves públicas atuais (como RSA-2048) deixem de ser considerados seguros.

Documento indicado: *NIST SP 800-131A Rev. 3*. Estipula o ciclo de vida e os prazos limite.

8.5.2 O Papel Contínuo da Entropia

Conteúdo: A garantia de que a segurança fundamental ainda depende da geração de números aleatórios de alta qualidade (RNG).

Documento indicado: *NIST SP 800-22*. Conecta os testes de aleatoriedade como pré-requisito indispensável.

9 NIST IR 8547 Transição para a Criptografia Pós-Quântica: Estratégias e Considerações

9.1 Urgencia Prática e o Modelo de Ameaça

O modelo de ameaça é uma ferramenta essencial para a segurança cibernética, permitindo que as organizações identifiquem, compreendam e mitiguem ameaças potenciais. Ele ajuda a priorizar os recursos de segurança, focando nas ameaças mais relevantes e perigosas. O modelo de ameaça é fundamental para o desenvolvimento de estratégias eficazes de defesa cibernética, garantindo que as organizações estejam preparadas para enfrentar os desafios atuais e futuros.

9.1.1 Ameaça Harvest now, Decrypt Later

A ameaça "Harvest now, Decrypt Later" refere-se à prática de coletar dados criptografados agora, com a intenção de descriptografá-los no futuro, quando os recursos computacionais ou as vulnerabilidades de segurança permitirem. Essa ameaça é particularmente preocupante para dados sensíveis que precisam ser protegidos por longos períodos, como informações pessoais, financeiras e de saúde. Para mitigar essa ameaça, é crucial adotar práticas de criptografia robustas e atualizadas, além de monitorar continuamente as vulnerabilidades e avanços tecnológicos que possam impactar a segurança dos dados.

9.1.2 Teorema de Mosca e a Linha do Tempo

O Teorema de Mosca é um conceito fundamental na segurança cibernética que destaca a importância de considerar o tempo ao avaliar ameaças e vulnerabilidades. Ele sugere que, para proteger adequadamente os sistemas, é necessário entender não apenas as ameaças atuais, mas também as ameaças futuras que podem surgir à medida que a tecnologia evolui. A linha do tempo é uma ferramenta útil para visualizar e planejar a defesa contra ameaças, permitindo que as organizações antecipem e se preparem para possíveis ataques futuros, garantindo uma postura de segurança proativa.

9.2 Novos Padrões e Categorias de Segurança

A evolução dos padrões de segurança é crucial para enfrentar as ameaças cibernéticas em constante mudança. Novos padrões e categorias de segurança são desenvolvidos para abordar as vulnerabilidades emergentes e garantir a proteção eficaz dos sistemas e dados. A adoção de padrões atualizados é essencial para manter a resiliência contra ataques

cibernéticos, promovendo uma abordagem de segurança mais robusta e adaptável às novas ameaças.

9.2.1 Publicações dos primeiros FIPS PQC

As publicações dos primeiros FIPS (Federal Information Processing Standards) para criptografia pós-quântica (PQC) representam um marco importante na evolução da segurança cibernética. Esses padrões são desenvolvidos para garantir que os sistemas de criptografia sejam resistentes a ataques de computadores quânticos, que têm o potencial de quebrar os métodos de criptografia tradicionais. A adoção desses padrões é crucial para proteger dados sensíveis e garantir a segurança a longo prazo, especialmente à medida que a tecnologia quântica avança e se torna mais acessível.

9.2.2 Categorias de Segurança Pós-Quântica (1 a 5)

As categorias de segurança pós-quântica são classificações que ajudam a identificar e categorizar os diferentes tipos de algoritmos de criptografia que são resistentes a ataques de computadores quânticos. Essas categorias incluem algoritmos baseados em reticulados, códigos, multivariados, hash-based e isogenias, cada um com suas próprias características e níveis de segurança. A compreensão dessas categorias é essencial para escolher os algoritmos mais adequados para proteger dados sensíveis contra ameaças futuras, garantindo uma postura de segurança robusta e resiliente.

9.3 Cronograma de Descontinuação (Deprecation)

O cronograma de descontinuação é um plano estratégico que define o processo e os prazos para a retirada de sistemas, tecnologias ou práticas de segurança obsoletas. Ele é essencial para garantir uma transição suave e segura para novas soluções, minimizando os riscos associados à manutenção de sistemas vulneráveis ou desatualizados. A implementação de um cronograma de descontinuação eficaz ajuda as organizações a se adaptarem às mudanças tecnológicas e a manterem uma postura de segurança proativa, garantindo a proteção contínua dos dados e sistemas.

9.3.1 Transição de Assinaturas Digitais (RSA, ECDSA, EdDSA)

A transição de assinaturas digitais, como RSA, ECDSA e EdDSA, é um processo crucial para garantir a segurança dos sistemas de criptografia à medida que novas ameaças emergem. Com o avanço da tecnologia, especialmente a computação quântica, é necessário migrar para algoritmos de assinatura digital mais robustos e resistentes a ataques futuros. A adoção de novos algoritmos de assinatura digital é essencial para proteger a integridade e

autenticidade dos dados, garantindo a segurança a longo prazo em um ambiente cibernético em constante evolução.

9.3.2 Transição de Estabelecimento de Chaves (DH, MQV, RSA)

A transição de estabelecimento de chaves, como DH (Diffie-Hellman), MQV (Menezes-Qu-Vanstone) e RSA, é um processo fundamental para garantir a segurança das comunicações criptografadas. Com o avanço da tecnologia, especialmente a computação quântica, é necessário migrar para algoritmos de estabelecimento de chaves mais robustos e resistentes a ataques futuros. A adoção de novos algoritmos de estabelecimento de chaves é essencial para proteger a confidencialidade e integridade das comunicações, garantindo a segurança a longo prazo em um ambiente cibernético em constante evolução.

9.4 Estratégias de Transição: Protocolos Híbridos

As estratégias de transição, como os protocolos híbridos, são abordagens que combinam algoritmos de criptografia tradicionais com algoritmos pós-quânticos para garantir a segurança durante o processo de migração. Esses protocolos permitem que as organizações mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à transição. A implementação de protocolos híbridos é uma estratégia eficaz para garantir a proteção contínua dos dados e sistemas durante a evolução da tecnologia, proporcionando uma transição suave e segura para o futuro da segurança cibernética.

9.4.1 Soluções Híbridas (PQC-Classical)

As soluções híbridas, que combinam algoritmos de criptografia pós-quântica (PQC) com algoritmos clássicos, são uma abordagem estratégica para garantir a segurança durante a transição para novas tecnologias de criptografia. Essas soluções permitem que as organizações mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à migração. A implementação de soluções híbridas é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

9.4.2 Protocolos Híbridos (TLS, SSH, IPsec)

Os protocolos híbridos, como TLS (Transport Layer Security), SSH (Secure Shell) e IPsec (Internet Protocol Security), são abordagens que combinam algoritmos de criptografia tradicionais com algoritmos pós-quânticos para garantir a segurança durante a transição para novas tecnologias de criptografia. Esses protocolos permitem que as organizações

mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à migração. A implementação de protocolos híbridos é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

9.4.3 Agilidade Criptográfica em Camadas de Infraestrutura

A agilidade criptográfica em camadas de infraestrutura é uma abordagem que permite a flexibilidade na escolha e implementação de algoritmos de criptografia em diferentes camadas de um sistema. Essa abordagem é crucial para garantir a segurança durante a transição para novas tecnologias de criptografia, permitindo que as organizações adotem soluções híbridas e se adaptem às mudanças nas ameaças cibernéticas. A implementação da agilidade criptográfica em camadas de infraestrutura é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

10 Crystals Kyber

10.1 Introdução

O CRYSTALS-Kyber é um sistema de criptografia de chave pública baseado em problemas de aprendizado com erros (LWE) e é considerado resistente a ataques de computadores quânticos. Ele é parte do projeto CRYSTALS (Cryptographic Suite for Algebraic Lattices) e é um dos candidatos para o padrão de criptografia pós-quântica do NIST (National Institute of Standards and Technology). O CRYSTALS-Kyber é projetado para ser eficiente em termos de tempo de execução e tamanho de chave, tornando-o uma opção viável para aplicações práticas de criptografia pós-quântica.

10.2 Estrutura do CRYSTALS-Kyber

O CRYSTALS-Kyber é baseado em um esquema de criptografia de chave pública que utiliza matrizes e vetores para realizar operações de criptografia e descriptografia. Ele é composto por três algoritmos principais: geração de chaves, criptografia e descriptografia.

11 CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)

11.1 Definição e Objetivos da PQC

Algoritmos clássicos projetados para resistir a ataques quânticos.

11.2 Paradigmas Matemáticos da PQC

Reticulados, códigos corretores de erro, funções hash e isogenias.

11.3 Criptografia Baseada em Reticulados

Introdução ao conceito de Lattices como base da nova segurança criptográfica.

11.4 Learning With Errors (LWE)

Fundamento matemático da pseudoaleatoriedade pós-quântica.

11.4.1 Implementação Didática em Java (Demonstração)

Implementação simplificada do LWE do zero em Java para fins didáticos, mostrando como o erro intencional funciona matematicamente antes de utilizar a biblioteca pronta.

11.5 Padronização Pós-Quântica

O papel do ML-KEM (Kyber) e o processo de padronização conduzido pelo NIST.

12 A TRANSIÇÃO PARA PQC NO ECOSISTEMA JAVA

12.1 Suporte à Criptografia Pós-Quântica no Java

Evolução do JDK e integração de algoritmos pós-quânticos em versões modernas (Java 21+).

12.2 Crypto-Agility

Boas práticas para desenvolvimento de sistemas criptográficos flexíveis e preparados para mudanças de algoritmo.

12.2.1 Implementação Prática: Demo de Crypto-Agility

Criação de uma interface Java que abstrai o algoritmo de geração de chaves, permitindo trocar de RSA para Kyber alterando apenas a configuração — sem reescrever o código da aplicação.

12.3 Comparativo de Modelos

Geração de chaves e aleatoriedade no modelo clássico versus modelo baseado em reticulados (Module-Lattice).

12.3.1 Implementação Prática: Benchmark Clássico vs. Kyber

Benchmark comparativo entre `java.security.SecureRandom` clássico e ML-KEM (Kyber) via Bouncy Castle, medindo tempo de geração de chaves, uso de memória e throughput. Inclui comparativo de tamanho de chaves entre RSA-2048 e Kyber. Nota: Confirmar com o orientador o uso da biblioteca Bouncy Castle como dependência, por ser a opção mais acessível para PQC em Java atualmente.

13 DISCUSSÃO E ANÁLISE CRÍTICA

13.1 Impacto em Desempenho

Custos computacionais, consumo de memória e latência — baseados nos resultados do benchmark da seção 6.3.1.

13.2 Barreiras de Adoção

Sistemas legados, limitações de hardware e resistência organizacional.

13.3 Implicações Sociais e Éticas

Soberania de dados, privacidade, vigilância e assimetria tecnológica.

14 CONCLUSÃO

14.1 Síntese dos Resultados

A inevitabilidade da transição criptográfica.

14.2 Resposta ao Problema de Pesquisa

A evolução da pseudoaleatoriedade como pilar da segurança pós-quântica.

14.3 Trabalhos Futuros

Geradores Quânticos de Números Aleatórios (QRNG) e integração híbrida TRNG + PQC.

Referências

- 1 National Institute of Standards and Technology. *NIST Post-Quantum Cryptography Standardization Process*. Gaithersburg, MD, 2023. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8413-upd1.pdf>>.
- 2 National Institute of Standards and Technology. *NIST Cryptographic Standards and Guidelines Development Process*. Gaithersburg, MD, 2016.
- 3 National Institute of Standards and Technology. *FIPS PUB 204 Transitioning to Post-Quantum Cryptography*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.204.pdf>>. Acesso em: 23 abr. 2026.
- 4 National Institute of Standards and Technology. *FIPS PUB 205 Transitioning to Post-Quantum Cryptography: Implementation and Operational Considerations*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.205.pdf>>. Acesso em: 23 abr. 2026.
- 5 National Institute of Standards and Technology. *NIST Special Publication 800-53 Revision 5*. Gaithersburg, MD, 2020. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>. Acesso em: 23 abr. 2026.
- 6 National Institute of Standards and Technology. *NIST Special Publication 800-131A Revision 2*. Gaithersburg, MD, 2019. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-131Ar2.pdf>>.